

The check is complete.

How complete is the check?



Complete

The planned review is complete. Its scope and limitations are documented below.

What we need from you

Nothing. This is for your information.

3 findings need attention; the working summary on the next page lists them.

Summary

Only the supply-chain leg's findings survived this run; four review areas need a second pass.

Five review legs ran; one returned its findings and four did not, so this report covers the supply-chain surface only. The pinning posture is strong, with two residual gaps in how vendored rules and Rust tooling are fetched.

Needs attention

	Severity	Finding	Where
1	Medium	Detection-rule vendoring clones by branch name rather than by commit	scripts/vendor-detection-rules.sh:12
2	Low	The Rust licence tool is pinned by version, not by hash	scripts/bootstrap-licenses.sh:4
3	Verified	Module, package and binary pinning is otherwise complete	go.sum:1

Scope and limits

- Worker envelopes for legs 1–4 were not retrieved; four of five review areas are unreported.
- No dynamic testing ran. Every claim below rests on reading the tree at this head.

Contents

Findings	2
Assessment	3
Security review — Lycaon (partial)	3
Supply-chain findings	3
Scanner findings	4
Evidence appendix	4
Sources	6
About this document	6

Findings

1. Detection-rule vendoring clones by branch name rather than by commit

Medium sc-1

Impact A force-push between the clone and the provenance commit lets the committed vendor drift from the intended revision.

Action Clone by commit SHA or tag and verify the SHA before writing the provenance manifest.

Where scripts/vendor-detection-rules.sh:12

2. The Rust licence tool is pinned by version, not by hash

Low sc-2

Impact Unlike the Go toolchain, the bootstrap re-resolves the dependency and cannot detect a substituted artifact.

Action Install with --locked against a committed lockfile, or pin the tool to a commit SHA.

Where scripts/bootstrap-licenses.sh:4

3. Module, package and binary pinning is otherwise complete

Verified sc-3

Impact Go modules, Bun packages and native binaries are all locked with integrity hashes and fail closed.

Action No action needed.

Where go.sum:1

Assessment

Security review — Lycaon (partial)

A broad security review ran against the accepted threat model documented in docs/security.md and SECURITY.md, split into five parallel read-only survey legs:

1. Confinement and egress boundary (lycaon/internal/exec, confine, egressproxy, egressclass, secretmatch)
2. API and authentication surface (lycaon/internal/api, settings)
3. MCP, tools, and trust plane (lycaon/internal/mcp, settings, catalog)
4. Web research and outbound egress controls (lycaon/internal/webresearch, api)
5. Supply chain and dependency posture (go.mod, package.json, bun.lock, scripts/, lycaon/config/)

All five workers completed. The completion envelopes for legs 1–4 were not retrieved before this forced closeout, so only the supply-chain leg's detailed findings appear below. The other four areas need a follow-up pass to surface, adjudicate, and report their findings.

Supply-chain findings

The supply-chain posture is heavily pinned and verification-oriented.

- **Medium — detection-rule vendoring tracks branch names, not commit pins, at clone time.** Vendored detection rules record upstream commit SHAs in provenance manifests after the clone, but the initial fetch uses a branch name. If a branch is force-pushed between clone and the provenance commit, the committed vendor can drift from the intended SHA. This is a residual risk, not an immediate gap, because the manifest is committed and can be audited.
- **Low — cargo-about bootstrap is pinned to a version, not a commit hash.** Unlike Go tooling, the Rust bootstrap path does not pin to a cryptographic hash.
 - The lockfile is committed but the bootstrap script re-resolves it.
 - cargo install --locked would close most of this.

The remaining supply-chain surface is well controlled:

Area	Mechanism	Verdict
Go modules	go.sum	locked
Den/Bun	bun.lock integrity hashes	locked
Native binaries	version + SHA-256, fail-closed	locked

Recommendations

1. **Re-run legs 1–4** and retrieve their worker envelopes so the full review can be completed.
2. **For detection-rule vendoring**, change the vendor script to clone by commit SHA or tag and verify the SHA before writing the provenance manifest.
3. For Rust bootstraps, pin cargo-about to a specific commit SHA or vendored lockfile rather than only a version.

4. **Adopt automated supply-chain SBOM generation** at release time and include it in the release artifacts.

```
func resolveWriteRoots(cfg Config) []string {  
    // A very long comment line that must character-break rather than run past the  
    right margin of the code panel.  
    return append(defaultRoots(cfg.HomeDir, cfg.CacheDir, cfg.StateDir),  
        cfg.ExtraRoots...)  
}
```

The floor stays systemic: containment, write-root grants, and egress host rules remain the boundary.

See the security doc <https://example.com/docs/security> for the accepted threat model.

Scanner findings

3 rows under 3 rules

Severity	Rule or advisory	Occurrences
High	go.lang.security.audit.net.use-tls.use-tls opengrep Connection is made without TLS verification enabled; a network attacker between the sidecar and the declared destination can read or rewrite the stream. lycaon/internal/egressproxy/dial.go 31	1 occurrence
Medium	supplychain.vendor.branch-not-pinned opengrep Clone tracks a branch name rather than a commit SHA. scripts/vendor-detection-rules.sh 12	1 occurrence
Low	supplychain.rust.cargo-about-version-pin opengrep cargo-about is pinned by version, not by commit hash. scripts/bootstrap-licenses.sh 4	1 occurrence

Evidence appendix

24 of 61 records listed · 2 cited · 18 grep, 3 list, 3 read

18 Grep records · all structured

Handle	Location	Matches	Cited by
da2aefce-7dec-4003-beeb-9a5a033302:grep#1	lycaon/internal/egressproxy/proxy.go	40 matches in 1 file	report
da2aefce-7dec-4003-beeb-9a5a033302:grep#2	lycaon/internal/egressproxy/socks5.go	7 matches in 1 file	
da2aefce-7dec-4003-beeb-9a5a033302:grep#3	lycaon/internal/secretmatch	22 matches in 4 files	
da2aefce-7dec-4003-beeb-9a5a033302:grep#4	lycaon/internal/egressproxy	61 matches in 9 files	
da2aefce-7dec-4003-beeb-9a5a033302:grep#5	docs	14 matches in 6 files	
da2aefce-7dec-4003-beeb-9a5a033302:grep#8	lycaon/internal/egressproxy/proxy.go	12 matches in 1 file	

Handle	Location	Matches	Cited by
da2aefce-7dec-4003-beeb-9a5a033302:grep#9	lycaon/internal/egressproxy/socks5.go	5 matches in 1 file	
da2aefce-7dec-4003-beeb-9a5a033302:grep#10	lycaon/internal/secretmatch	103 matches in 5 files	
da2aefce-7dec-4003-beeb-9a5a033302:grep#11	lycaon/internal/egressproxy	18 matches in 3 files	
da2aefce-7dec-4003-beeb-9a5a033302:grep#12	docs	31 matches in 11 files	
da2aefce-7dec-4003-beeb-9a5a033302:grep#15	lycaon/internal/egressproxy/proxy.go	9 matches in 1 file	
da2aefce-7dec-4003-beeb-9a5a033302:grep#16	lycaon/internal/egressproxy/socks5.go	145 matches in 2 files	
da2aefce-7dec-4003-beeb-9a5a033302:grep#17	lycaon/internal/secretmatch	6 matches in 2 files	
da2aefce-7dec-4003-beeb-9a5a033302:grep#18	lycaon/internal/egressproxy	27 matches in 4 files	
da2aefce-7dec-4003-beeb-9a5a033302:grep#19	docs	166 matches in 24 files	
da2aefce-7dec-4003-beeb-9a5a033302:grep#22	lycaon/internal/egressproxy/proxy.go	187 matches in 3 files	
da2aefce-7dec-4003-beeb-9a5a033302:grep#23	lycaon/internal/egressproxy/socks5.go	2 matches in 1 file	
da2aefce-7dec-4003-beeb-9a5a033302:grep#24	lycaon/internal/secretmatch	11 matches in 3 files	

3 List records · none cited · all structured

Handle	Location
da2aefce-7dec-4003-beeb-9a5a033302:list#6	lycaon/internal/egressclass
da2aefce-7dec-4003-beeb-9a5a033302:list#13	lycaon/internal/egressclass
da2aefce-7dec-4003-beeb-9a5a033302:list#20	lycaon/internal/egressclass

3 Read records · all structured

Handle	Location	Cited by
--------	----------	----------

Handle	Location	Cited by
da2aefce-7dec-4003-beeb-9a5a033302:read#7	lycaon/internal/egressproxy/dial.go:80-88	report
	<pre> 80 var o ProxyOptions 81 if len(opts) > 0 { 82 o = opts[0] 83 } 84 listenHTTP := o.ListenHTTP 85 if listenHTTP == nil { 86 listenHTTP = net.Listen 87 } ... 1 more line </pre>	
da2aefce-7dec-4003-beeb-9a5a033302:read#14	lycaon/internal/egressproxy/dial.go:80-88	
	<pre> 80 var o ProxyOptions 81 if len(opts) > 0 { 82 o = opts[0] 83 } 84 listenHTTP := o.ListenHTTP 85 if listenHTTP == nil { 86 listenHTTP = net.Listen 87 } ... 1 more line </pre>	
da2aefce-7dec-4003-beeb-9a5a033302:read#21	lycaon/internal/egressproxy/dial.go:80-88	
	<pre> 80 var o ProxyOptions 81 if len(opts) > 0 { 82 o = opts[0] 83 } 84 listenHTTP := o.ListenHTTP 85 if listenHTTP == nil { 86 listenHTTP = net.Listen 87 } ... 1 more line </pre>	

Sources

Source	Host	Cited by
Sigma rule basics	sigmahq.io https://sigmahq.io/docs/basics/rules.html	report
Actions, resources, and condition keys for AWS services	docs.aws.amazon.com https://docs.aws.amazon.com/service-authorization/latest/reference/reference_policies_actions-resources-contextkeys.html	report

About this document

Produced by Painted Wolf Code, paintedwolf.ai
Workflow security-survey 1.0.0
Run dac40de1-903e-557b-b7c8-480daee5f82f
Project lycaon
Head 115fcab4c9a1d0e7f2b3c4d5e6f708192a3b4c5d
Started 13 August 2026, 14:44 UTC
Completed 13 August 2026, 16:09 UTC
Model claude-opus-5 via anthropic
Workers 5 legs: security-reviewer x5
Evidence 61 records observed, 24 listed

This document is a projection of the run's durable records — its closeout, review verdicts, scan findings, evidence ledger, and visuals — rendered deterministically: the same records produce byte-identical output. The records, not the document, are the record of the outcome.